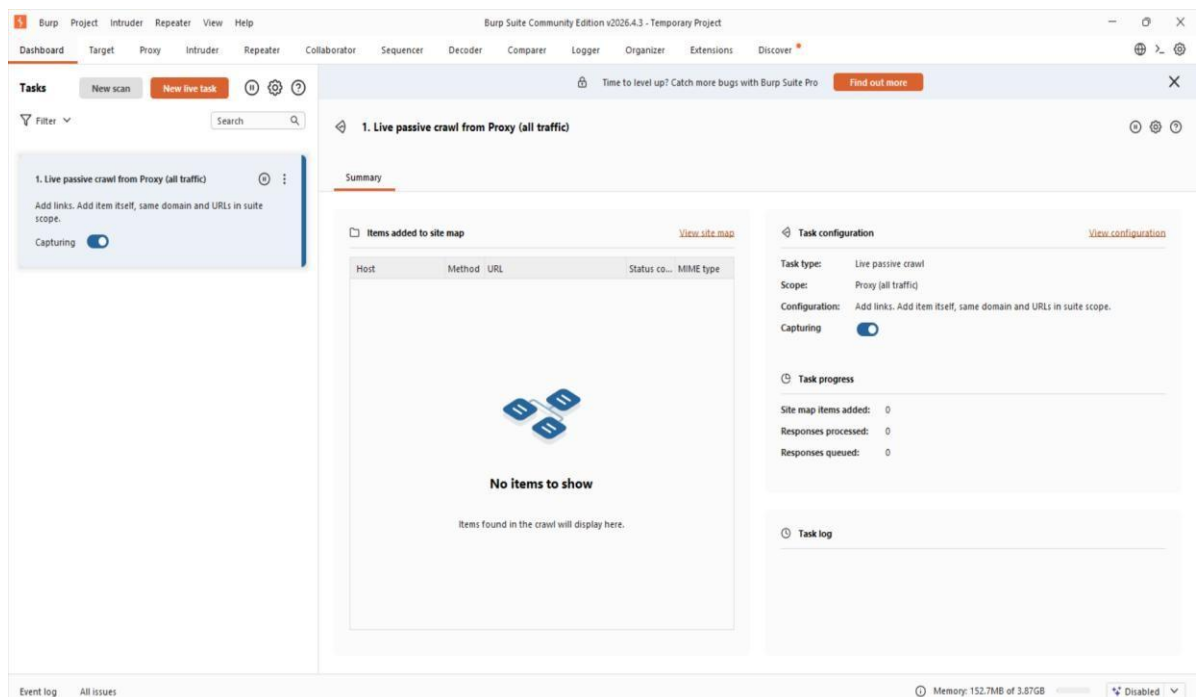


Task-11 Describing VAPT tools (Burp Suite, OWASP)

1. **Download and install Burp Suite Community Edition on your system, then launch it and take a screenshot of the main dashboard.**

Ans:



- ⇒ Burp Suite Community Edition was successfully installed and launched on the system.
- ⇒ The main dashboard was displayed successfully.

For Kali Linux:

- sudo apt update
- sudo apt install burpsuite -y

- 2. Use Burp Suite's Proxy feature to intercept HTTP requests while browsing the login page of any demo web app (such as <http://testphp.vulnweb.com/>) and list the intercepted request headers.**

Ans:

Intercepting HTTP Requests Using Burp Suite Proxy

Objective:

- To intercept and analyzed HTTP requests using Burp Suite Community Edition while browsing a demo web application.

Procedure:

- Opened Burp Suite Community Edition.
- Navigated to the Proxy tab and enabled the Intercept feature.
- Opened the demo website login page:
<http://testphp.vulnweb.com/login.php>
- Captured the HTTP request using Burp Suite Proxy.
- Examined the intercepted request and identified the request headers.

Intercepted HTTP Request Headers:

- GET /login.php HTTP/1.1
- Host: testphp.vulnweb.com
- Accept-Language: en-US,en;q=0.9
- Upgrade-Insecure-Requests: 1
- User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36

Accept:

- text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,;q=0.8,application/signedexchange;v=b3;q=0.7

TOPS TECH Task 11 (CS)

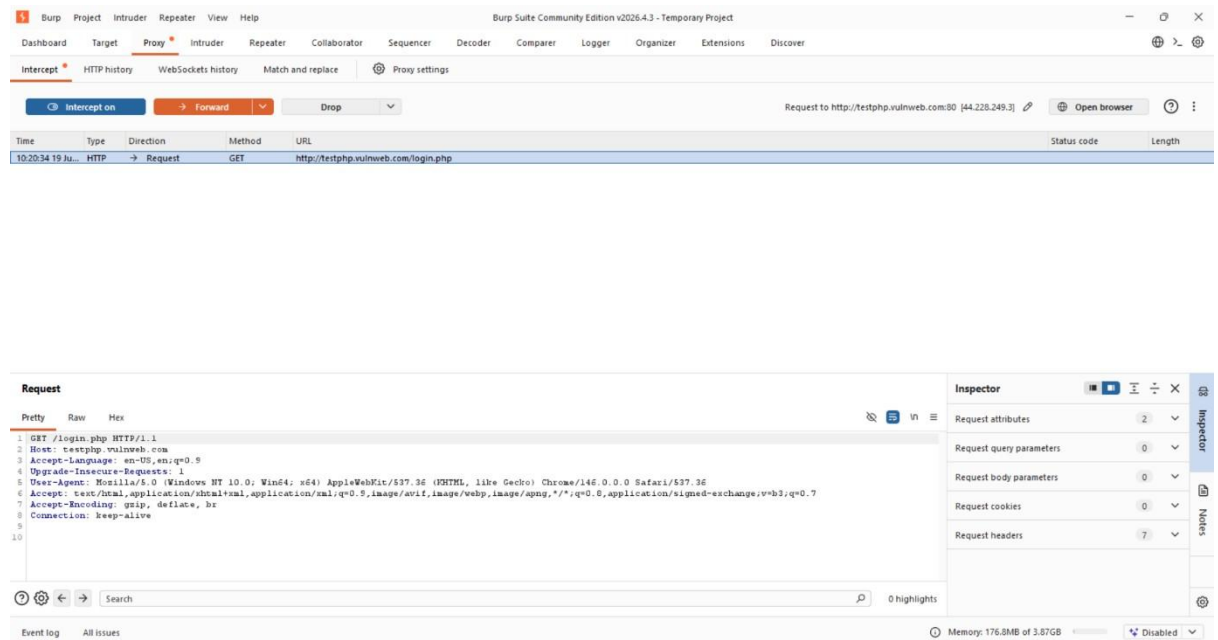
Accept-Encoding: o

gzip, deflate, br

Connection: o

keep-alive

- ⇒ The HTTP request generated while accessing the login page of the demo website was successfully intercepted using Burp Suite Proxy.
- ⇒ The captured request headers were analyzed to understand the communication between the client browser and the web server.



3. Use Burp Suite's Proxy feature to intercept HTTP requests while browsing the login page of any demo web app (such as <http://testphp.vulnweb.com/>) and list the intercepted request headers.

Ans:

Identification of Open-Source VAPT Tools from OWASP

Objective:

TOPS TECH Task 11 (CS)

To explore OWASP resources and identify open-source Vulnerability Assessment and Penetration Testing (VAPT) tools along with their primary purposes.

Tools Identified:

1. OWASP ZAP (Zed Attack Proxy):

Purpose: o OWASP ZAP is an open-source web application security scanner used to identify vulnerabilities in web applications through automated and manual testing techniques.

2. OWASP Dependency-Check Purpose:

- o OWASP Dependency-Check is a software composition analysis tool that detects known vulnerabilities in third-party libraries and project dependencies.

3. DefectDojo Purpose: o DefectDojo is an open-source vulnerability management and reporting platform used to aggregate, track, prioritize, and manage security findings from multiple security tools.

Result:

- o Three open-source VAPT tools provided by OWASP were successfully identified and their primary purposes were studied.
- o These tools assist security professionals in vulnerability assessment, dependency analysis, and vulnerability management.

4. **Perform a basic vulnerability scan on <http://testphp.vulnweb.com/> using OWASP ZAP (or any OWASP-listed tool), and list two vulnerabilities or alerts detected by the tool.**
Hint: Use the 'Quick Start' or 'Automated Scan' option for faster results.

Ans:

Vulnerability Assessment Using OWASP ZAP

Objective:

- To perform a basic vulnerability assessment on a demo web application using OWASP ZAP and identify security alerts generated during the scan.

Target URL:

- <https://demo.testfire.net>

Vulnerabilities / Alerts Detected:

1. SQL Injection:

Risk Level: o
High

Description:

- o The application appears to be vulnerable to SQL Injection. o This vulnerability may allow attackers to manipulate database queries and gain unauthorized access to sensitive information.

2. Cross-Site Scripting (Reflected):

TOPS TECH Task 11 (CS)

Risk Level: High

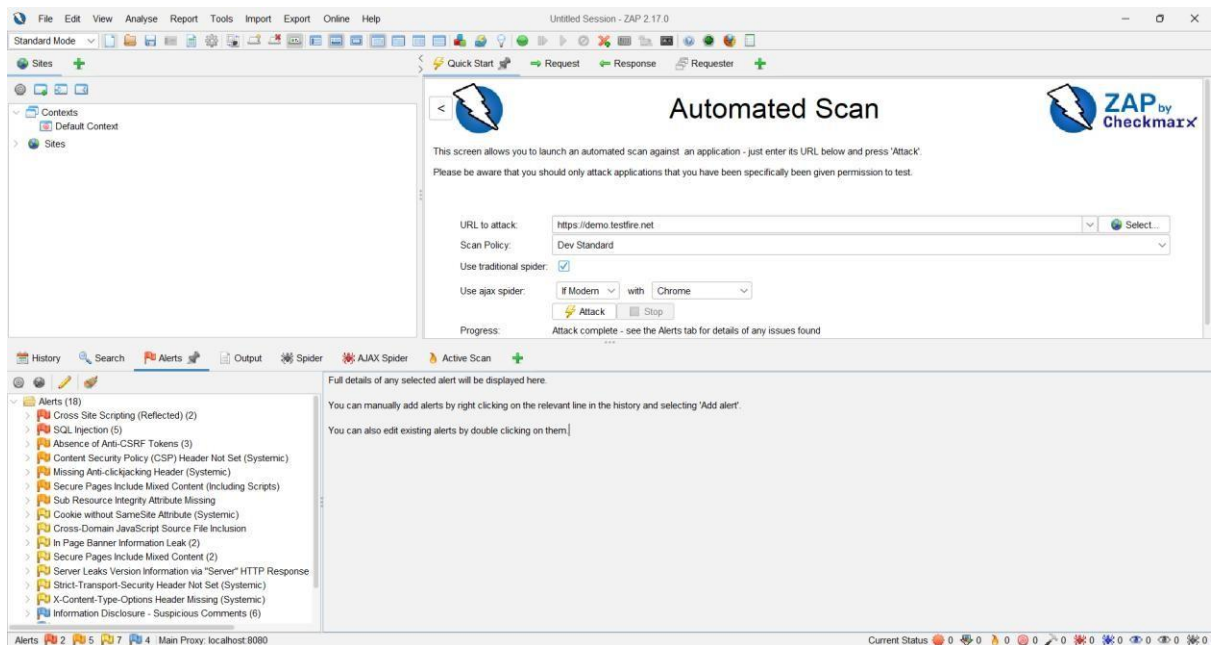
Description:

n:

- The application reflects user-supplied input without proper validation or encoding. This may allow attackers to execute malicious scripts in a user's browser.

Result:

- The OWASP ZAP scan was successfully performed on the target web application.
- Multiple security vulnerabilities were identified, including SQL Injection and Cross-Site Scripting (Reflected).
- The scan demonstrated the effectiveness of automated vulnerability assessment tools in detecting security weaknesses.



5. Use ChatGPT or Copilot to generate a step-by-step guide for running a simple SQL Injection test using Burp Suite on a demo site, then follow the steps and note any differences or issues you faced.

Hint: Paste the AI-generated steps and your observations in your submission.

Ans:

AI-Generated Step-by-Step Guide for SQL Injection Testing Using Burp Suite

Objective:

- To understand how Burp Suite can be used to inspect and analyze web application requests during a basic SQL Injection security assessment on a legal demo website.

AI-Generated Steps:

Step 1: Launch Burp Suite:

- Open Burp Suite Community Edition and create a Temporary Project using the default settings.

Step 2: Configure the Browser Proxy:

- Ensure that the browser traffic is routed through Burp Suite by configuring the proxy settings to use:
 - Host: 127.0.0.1 o Port: 8080

Step 3: Enable Interception:

- Navigate to the Proxy tab and enable the Intercept feature.

Step 4: Access the Demo Website:

TOPS TECH Task 11 (CS)

Open a legal demo web application in the browser and navigate to a page containing a login form or search form.

Step 5: Capture the Request:

- Submit the form and observe the HTTP request captured by Burp Suite.

Step 6: Review Request Parameters:

- Examine the request method, URL, headers, cookies, and form parameters to understand how user input is transmitted to the server.

Step 7: Send the Request to Repeater:

- Right-click the captured request and select "Send to Repeater".

Step 8: Analyze Server Responses:

- Use Repeater to resend the request and compare server responses while observing how the application handles different inputs.

Step 9: Document Findings:

- Record observations regarding request structure, response behaviour, and any security-related information identified during testing.

Observations:

- Burp Suite successfully intercepted HTTP requests generated by the browser.
- Request headers and parameters were visible and could be analyzed.
- The Repeater tool allowed repeated inspection of requests and responses.
- The activity helped in understanding how web applications process user-supplied input.

TOPS TECH Task 11 (CS)

- No unauthorized exploitation or modification of the target application was performed.

Issues Faced:

- The original demo website (testphp.vulnweb.com) was temporarily unreachable and returned connection timeout errors.

TOPS TECH Task 11 (CS)

- An alternative demo website (<https://demo.testfire.net>) was used for testing purposes.
- Proxy settings had to be verified to ensure that browser traffic was correctly routed through Burp Suite.

Result:

- The AI-generated procedure was successfully followed to understand the workflow of request interception and analysis using Burp Suite.
- The exercise improved understanding of web application traffic inspection and security testing methodologies.